

VIRTUAL CISO AND OTHER SECURITY ROLES OVERVIEW

VERSION: 1.4a
DATE: 26/03/2019
AUTHOR: SYLVAIN MARTINEZ
REFERENCE: ES-INTERNAL
CLASSIFICATION: PUBLIC



CONTENTS

CONTEXT	VCISO	OTHER ROLES	TRAINING & CAREER	NEXT STEPS
Context	- Virtual CISO role overview; - Virtual CISO Role Scope;	Core cyber security roles overview;	- Training and career plan strategy; - Training and career plan example.	Next Steps Objectives.



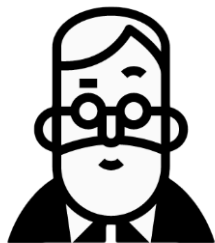
THIS DOCUMENT WAS CREATED WITH THE MAURITIUS MARKET IN MIND, HOWEVER IT CAN BE RELEVANT TO MOST PARTS OF THE WORLD, ESPECIALLY WHEN IT COMES TO SMALL AND MEDIUM ENTERPRISES.



MANY COMPANIES DO NOT HAVE DEDICATED SECURITY TEAMS/STAFF OR ONLY OPERATE WITH A LIMITED SECURITY TEAM BOTH IN TERMS OF NUMBER AND EXPERTISE.



MAJOR CYBER SECURITY CHALLENGES INCLUDE DECIDING WHAT ACTIVITIES TO PRIORITISE, WHERE TO START, HOW TO DELIVER VARIOUS CYBER SECURITY PROJECTS AND PROGRAMS AS WELL AS KNOWING WHAT IS BEST FOR THE PROFILE OF THE COMPANY.



RECRUITING CYBER SECURITY STAFF WITH A LOT OF EXPERTISE IS DIFFICULT TO FIND AND OFTEN AT A HIGH PRICE. ONE SOLUTION IS TO TURN TO EXTERNAL/OUTSOURCED CONSULTANTS TO PROVIDE CYBER SECURITY EXPERTISE AND GROW INTERNAL EXPERTISE IN PARALLEL.

VIRTUAL CISO ROLE OVERVIEW



THE ROLE OF A CHIEF INFORMATION SECURITY OFFICER (CISO) IS TO BE RESPONSIBLE FOR THE COMPANY'S OVERALL CYBER SECURITY EFFORTS: STRATEGY, ROADMAPS, TECHNOLOGY CHOICES, SECURITY BUDGET, SECURITY STAFF, SECURITY PROJECTS, CYBER RISKS ACCOUNTABILITY, ETC.



THE ROLE OF A VIRTUAL CISO (VCISO) IS MORE LIMITED AS IT IS EXTERNAL TO THE COMPANY. IT IS PRIMARILY AIMED AT HELPING A COMPANY WITH A SMALL OR NON EXISTENT SECURITY TEAM TO PRIORITIZE THEIR SECURITY RELATED ACTIVITIES AND OVERSEE/ADVISE ON KEY SECURITY RELATED DECISIONS



THE MANDATE, ACCOUNTABILITIES AND RESPONSIBILITIES OF A VCISO DEPENDS OF THE COMPANY'S ABILITY AND WILLINGNESS TO DELEGATE RESPONSIBILITIES AND AUTHORITY TO AN EXTERNAL CONSULTANT

VIRTUAL CISO ROLE SCOPE

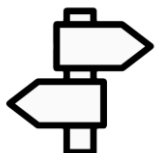
BELOW IS A LIST OF ACTIVITIES THAT ARE TYPICALLY IN AND OUT OF SCOPE FOR A VIRTUAL CISO

IN SCOPE	OUT OF SCOPE
DEFINITION AND IMPLEMENTATION OF THE COMPANY'S SECURITY STRATEGY AND ROADMAP	SECURITY BUDGET
SECURITY RELATED PROJECTS OVERSIGHT AND MANAGEMENT	SECURITY STAFF MANAGEMENT LINE
INDEPENDENT ADVICE ON SECURITY RELATED TECHNOLOGIES AND BEST PRACTISES	EXTERNAL CONTRACT ASSIGNMENTS
BOARD REPRESENTATION	OVERALL SECURITY RISKS ACCOUNTABILITY
FOCAL POINT OF CONTACT FOR ALL SECURITY DECISIONS (TRAINING, PROJECTS, ETC.)	SECURITY OPERATIONAL TASKS

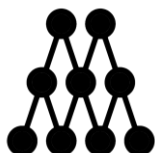
CORE CYBER SECURITY ROLES OVERVIEW

ROLE	TYPE	SCOPE	NB DESIRED	EMPLOYMENT OPTIONS	EMPLOYMENT TYPE	BASIC SALARY (MUR)	MARKET AVAILABILITY
CISO	MANAGEMENT	Driving Strategy and roadmap, project and technology oversight	1x	- IN-HOUSE - EXTERNAL - OUTSOURCED	- FULL TIME - PARTIAL	150K – 250K	RARE, MOSTLY EXPAT
CYBER SECURITY MANAGER	MANAGEMENT	Managed Security team and projects' delivery	1x	- IN-HOUSE - EXTERNAL - OUTSOURCED	- FULL TIME - PARTIAL	100K – 200K	NOT COMMON
CYBER SECURITY CONSULTANT	CONSULTING	Overall advise on specific security related project based on best practices	1x	- IN-HOUSE - EXTERNAL - OUTSOURCED	- FULL TIME - PART TIME - AD-HOC	75K – 150K	RARE
CYBER SECURITY OFFICER	GENERALIST	Operational tasks such as Vulnerability Assessment	2x	- IN-HOUSE - EXTERNAL - OUTSOURCED	- FULL TIME	50K – 150K	COMMON
CYBER SECURITY RISK OFFICER	SPECIALIST	Internal and external Risk identification, documentation and review	1x	- IN-HOUSE - EXTERNAL - OUTSOURCED	- FULL TIME	75K – 150K	RARE, MOSTLY EXPAT
CYBER SECURITY INCIDENT OFFICER	SPECIALIST	Driving incident planning, simulation and management	1x	- IN-HOUSE - EXTERNAL - OUTSOURCED	- FULL TIME	50K – 150K	NOT COMMON
CYBER FORENSICS OFFICER	SPECIALIST	In charge of investigation during incidents to find root causes	1x	OUTSOURCED	- AD-HOC	100K – 200K	VERY RARE, MOSTLY EXPAT
CYBER SECURITY ARCHITECT	CONSULTING	Designing and Assessing current and future IT Architecture security	1x	- EXTERNAL - OUTSOURCED	- FULL TIME - PART TIME	100K – 200K	RARE

TRAINING AND CAREER PLAN STRATEGY



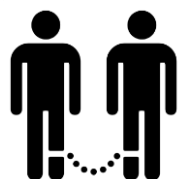
TO SUCCESSFULLY DEVELOP IN-HOUSE CYBER SECURITY CAPABILITIES AND GROW INTERNAL RESOURCES, A CLEAR SET OF CAREER PATHS INTO THAT PROFESSION SHOULD FIRST BE DEFINED



SUCH CAREER PATHS SHOULD OFFER DIFFERENT TYPE OF ROLES, FROM TECHNICAL TO MANAGERIAL IN ORDER TO BETTER SUIT VARIOUS STAFF ASPIRATIONS



STAFF SUPPORT FROM UPPER MANAGEMENT AND ADEQUATE CONTINUOUS TRAINING TO SUCCEED IN THOSE ROLES WILL BE REQUIRED



WHENEVER POSSIBLE, ANY EXTERNAL CONSULTANT WORKING IN/FOR THE ORGANIZATION SHOULD BE PAIRED WITH AN INTERNAL STAFF AND THEIR WORK SHADOWED SO KNOWLEDGE TRANSFER OCCURS



LIKE WITH MANY OTHER PROFESSION, SOME KNOWLEDGE ONLY COMES FROM EXPERIENCE. FURTHERMORE, MOST SECURITY PROFESSIONALS TEND TO SPECIALIZE IN ONE SPECIFIC AREA (I.E.: FORENSICS, VULNERABILITY ASSESSMENT) AND IT IS VERY RARE TO GET A SPECIALIST IN MANY DIFFERENT AREAS OF SECURITY EXPERTISE

TRAINING AND CAREER PLAN EXAMPLE

		EXPERIENCE					
		0+ Years	3+	5+	7+	10+	15+
CAREER PATH	GENERALIST	SO1 Security Officer L1	SO2 Security Officer L2	SO3 Security Officer L3			
	SPECIALIST		SS1 Security Specialist L1	SS2 Security Specialist L2	SS3 Security Specialist L3		
	CONSULTING			SC1 Security Consultant L1	SC2 Security Consultant L2	SC3 Security Consultant L3	
	MANAGEMENT				SM1 Security Manager L1	SM2 Security Manager L2	SM3 Security Manager L3
MINIMUM EXPERIENCE REQUIRED	CISO						X
	CYBER SECURITY MANAGER				X		
	CYBER SECURITY CONSULTANT			X			
	CYBER SECURITY OFFICER	X					
	CYBER SECURITY RISK OFFICER			X			
	CYBER SECURITY INCIDENT OFFICER		X				
	CYBER FORENSICS OFFICER				X		
	CYBER SECURITY ARCHITECT					X	
TRAINING	TYPE OF TRAINING/CERT	- Basic Security Training - Certification after 6 months - Online Training	- General Security Training - Incident Handler Training - Online Training	- More Specialised Training - On premises and abroad Training - Talk at Local Conferences	- Advanced Training - Industry Recognised - Abroad Training - Talk at International Conferences	- Leadership Training - Business Training - Internal Training	- Advanced Leadership Training - Recognised Expert
	Examples	CIHE, CEH	GSEC, GCIH	GCFA, GPEN	GXPEN, CISSP	TOGAF 9	CISM, CISSP

TRAINING AND CAREER PLAN OVERVIEW

NEXT STEP	GOAL
ASSESS YOUR COMPANY RISK PROFILE	TO EVALUATE AND DOCUMENT THE LEVEL OF CYBER SECURITY RISKS RELATED TO THE NATURE AND IMPLEMENTATION OF YOUR BUSINESS
ASSESS YOUR COMPANY SECURITY MATURITY	TO IDENTIFY THE ELVEL OF SECURITY IMPLEMENTED IN YOUR HUMAN, PROCESS AND TECHNOLOGY GAPS RELATED TO YOUR RISK PROFILE
ASSESS YOUR CURRENT COMPANY SECURITY PRIORITIES AND CAPABILITY	TO IDENTIFY WHAT CYBER SECURITY ROLES ARE REQUIRED TO DELIVER YOUR CYBER SECURITY PRIORITIES
IDENTIFY IN HOUSE RESOURCES THAT CAN BE UP-SKILLED TO FILL SOME OF THE ROLES	TO LEVERAGE YOUR EXISTING WORK FORCE TO FILL SOME OF THE CYBER SECURITY ROLES GAPS
DEVELOP A TRAINING OR RECRUITMENT PROGRAM	TO DEVELOP AND UPSKILL YOUR EXISTING STAFF AS WELL AS RECRUIT EXTRA STAFF IF NEEDED

ABOUT ELYSIUMSECURITY LTD.

ELYSIUMSECURITY provides a portfolio of **Strategic** and **Tactical Services** to help companies **protect** and **respond** against **Cyber Security Threats**. We differentiate ourselves by offering **discreet, tailored** and **specialized** engagements.

ELYSIUMSECURITY provides **high level expertise** gathered through years of **best practices experience** in large international companies allowing us to provide advice best suited to your **business operational model** and **priorities**.

ELYSIUMSECURITY operates in **Mauritius** and in **Europe**, a ***boutique style*** approach means we can **easily adapt** to your business operational model and requirements to provide a **personalized service** that fits your working environment.

ELYSIUMSECURITY provides **practical expertise** to **identify vulnerabilities**, assess their **risks** and **impact**, **remediate** those risks, **prepare** and **respond** to incidents as well as raise **security awareness** through an organization.

